

Name – Harshwardhan Malojirao Galande

Roll No – TYA 45

Session Hijacking Practical Using DVWA on Windows

PART 1 — Install XAMPP

Step 1 — Download XAMPP

Open: [XAMPP Official Website](https://www.apachefriends.org/)

Download:

- XAMPP for Windows

Step 2 — Install XAMPP

Run installer.

Keep default components:

- Apache
- MySQL
- PHP
- phpMyAdmin

PART 2 — Start XAMPP

Step 3 — Open XAMPP Control Panel

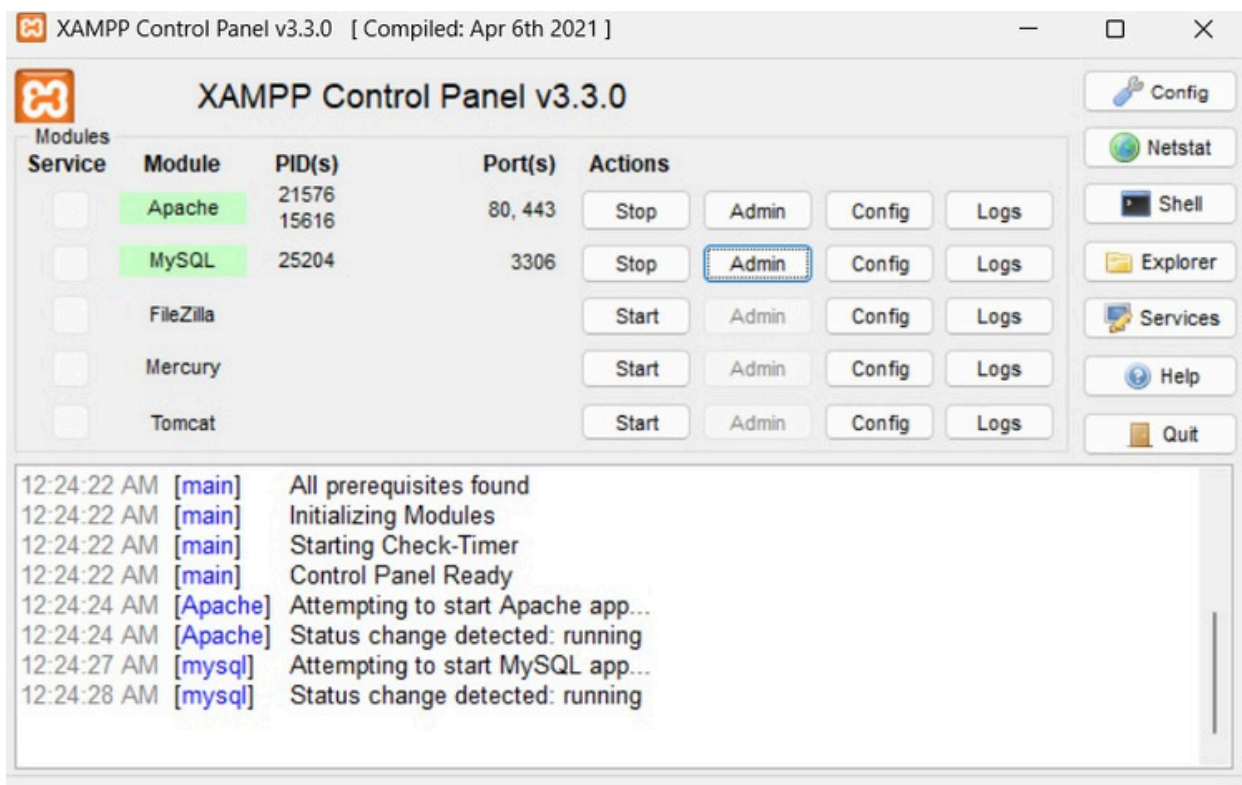
Search: XAMPP Control Panel

Open it.

Step 4 — Start Services

Click:

- Start Apache
- Start MySQL



Both should turn green.

PART 3 — Download DVWA

Step 5 — Download DVWA

Open: [DVWA GitHub Download](#)

Click: code and download zip

PART 4 — Setup DVWA

Step 6 — Extract DVWA

Extract ZIP file.

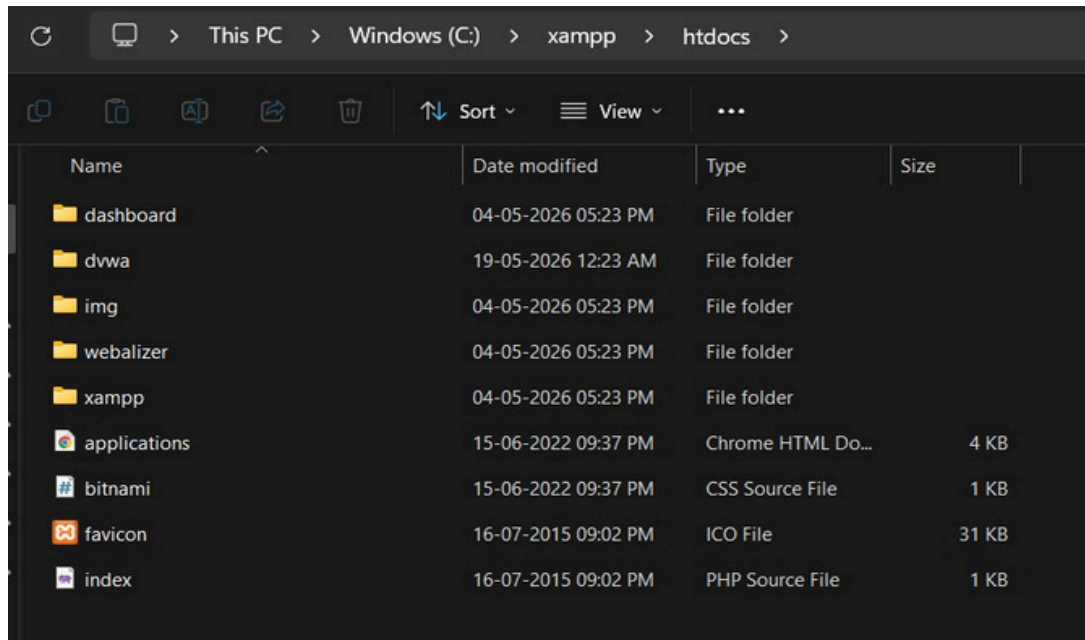
Rename folder to: dvwa

Name	Date modified	Type	Size
▼ Today			
DVWA-master	19-05-2026 12:15 AM	Compressed (zipp...	1,032 KB
dvwa	19-05-2026 12:28 AM	File folder	

Step 7 — Move DVWA Folder

Go to: C:\xampp\htdocs\ Paste dvwa folder there.

So path becomes: C:\xampp\htdocs\dvwa



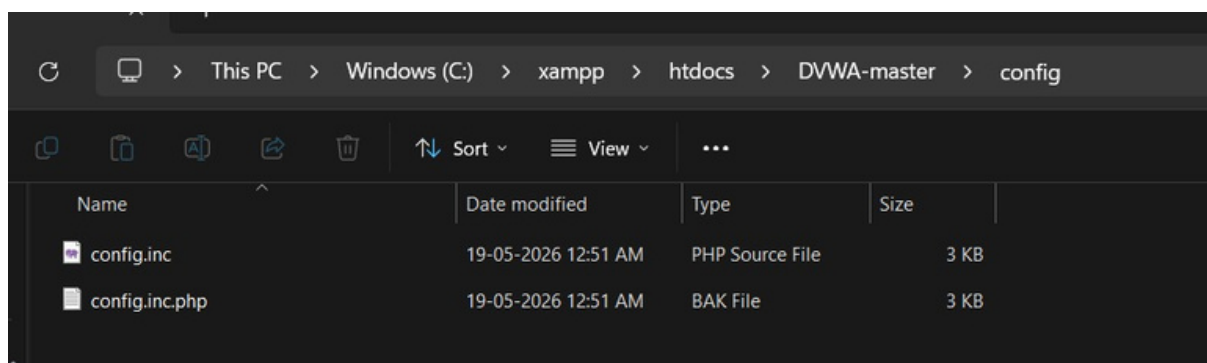
Step 8 — Configure DVWA

Opened: C:\xampp\htdocs\DVWA-master\config

Renamed:

bconfig.inc.php.dist

to: config.inc.php



Step 9 — Configure Database Credentials

Opened config.inc.php.

Modified database credentials:

```
$_DVWA[ 'db_user' ] = 'root';
```

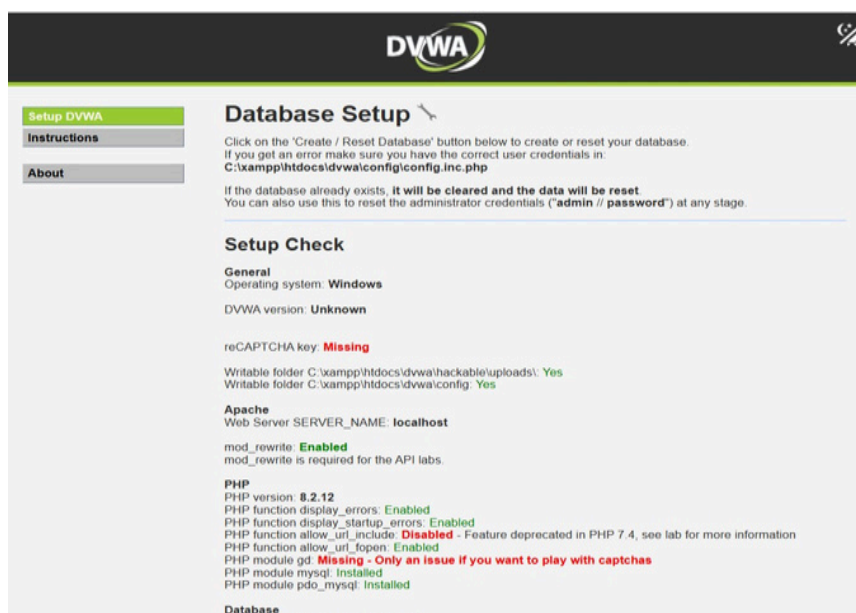
```
$_DVWA[ 'db_password' ] = '';
```

```
config.inc.php X
C: > xampp > htdocs > DVWA-master > config > config.inc.php
1  <?php
2
3  # If you are having problems connecting to the MySQL database and all of the variables below are correct
4  # try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
5  # Thanks to @digininja for the fix.
6
7  # Database management system to use
8  $DBMS = getenv('DBMS') ? : 'MySQL';
9  #$DBMS = 'PGSQL'; // Currently disabled
10
11 # Database variables
12 # WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
13 # Please use a database dedicated to DVWA.
14 #
15 # If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
16 # See README.md for more information on this.
17 $_DVWA = array();
18 $_DVWA[ 'db_server' ] = getenv('DB_SERVER') ? : '127.0.0.1';
19 $_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ? : 'dvwa';
20 $_DVWA[ 'db_user' ] = getenv('DB_USER') ? : 'root';
21 $_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ? : '';
22 $_DVWA[ 'db_port' ] = getenv('DB_PORT') ? : '3306';
```

Step 10 — Open DVWA Setup Page

Opened browser and visited: <http://localhost/DVWA-master/setup.php>

DVWA setup page opened successfully.



Step 12 — Create Database

Clicked: Create / Reset Database

Database was created successfully.

Step 13 — Login to DVWA

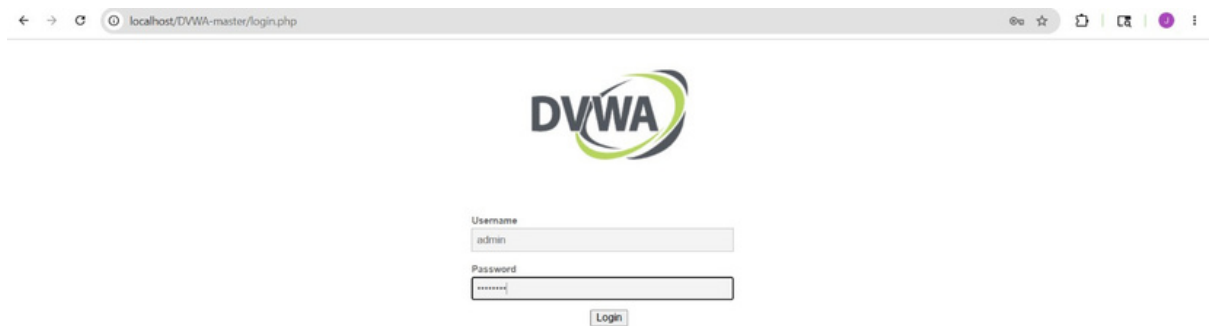
Opened:

<http://localhost/DVWA-master/login.php>

Logged in using:

Username: admin

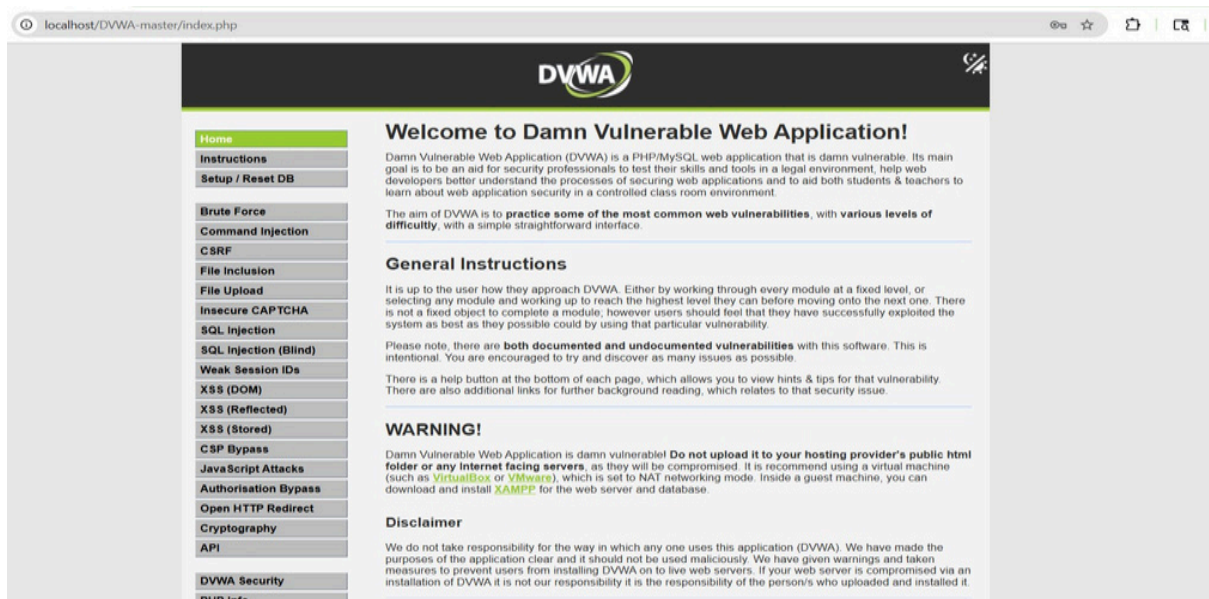
Password: password



Step 14 — Open Victim Session

Opened DVWA in Chrome browser.

Logged into the application successfully.



Step 15 — Access Browser Cookies

Pressed:

F12

Opened Developer Tools.

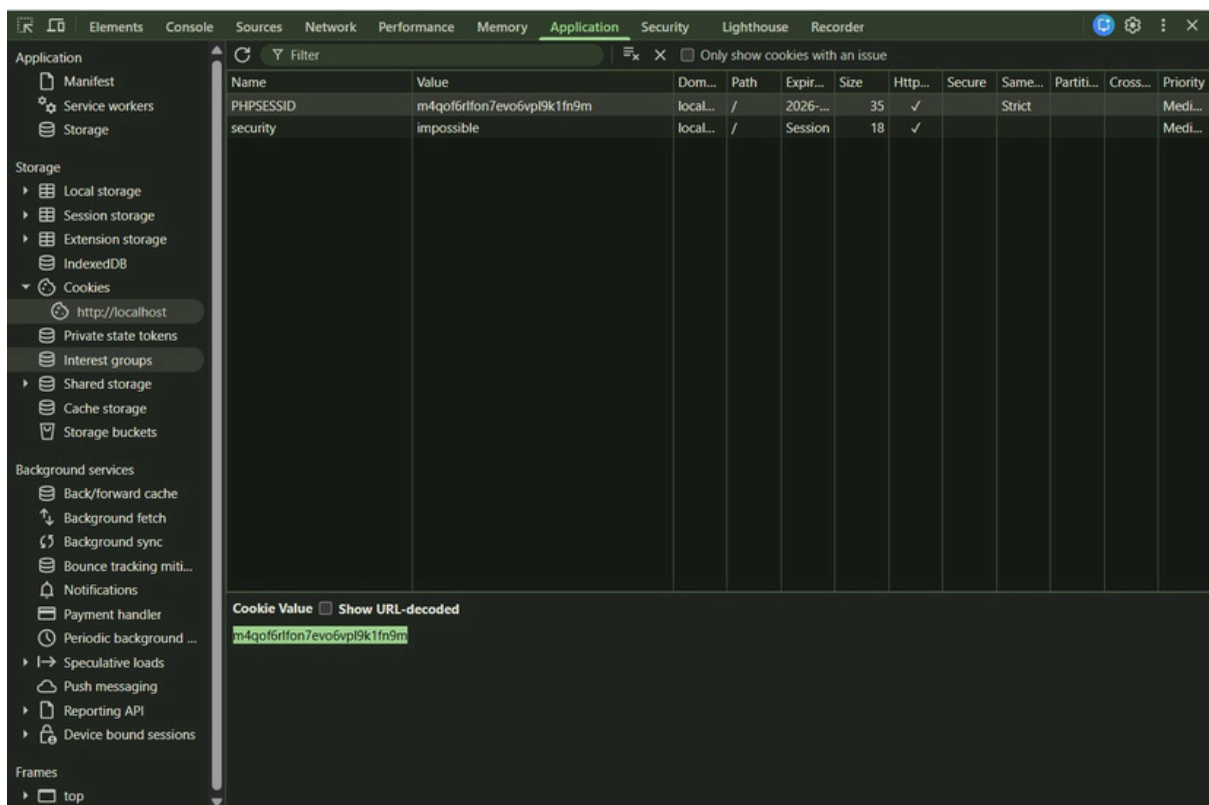
Navigated to:

- Application/Storage
- Cookies
- localhost

Located:

PHPSESSID

m4qof6rlfon7evo6vpl9k1fn9m



Step 16 — Open Attacker Browser

Opened Firefox browser.

Visited: <http://localhost/DVWA-master/login.php>

Did not login.

Step 17 — Replace Session Cookie

Opened Developer Tools in Firefox.

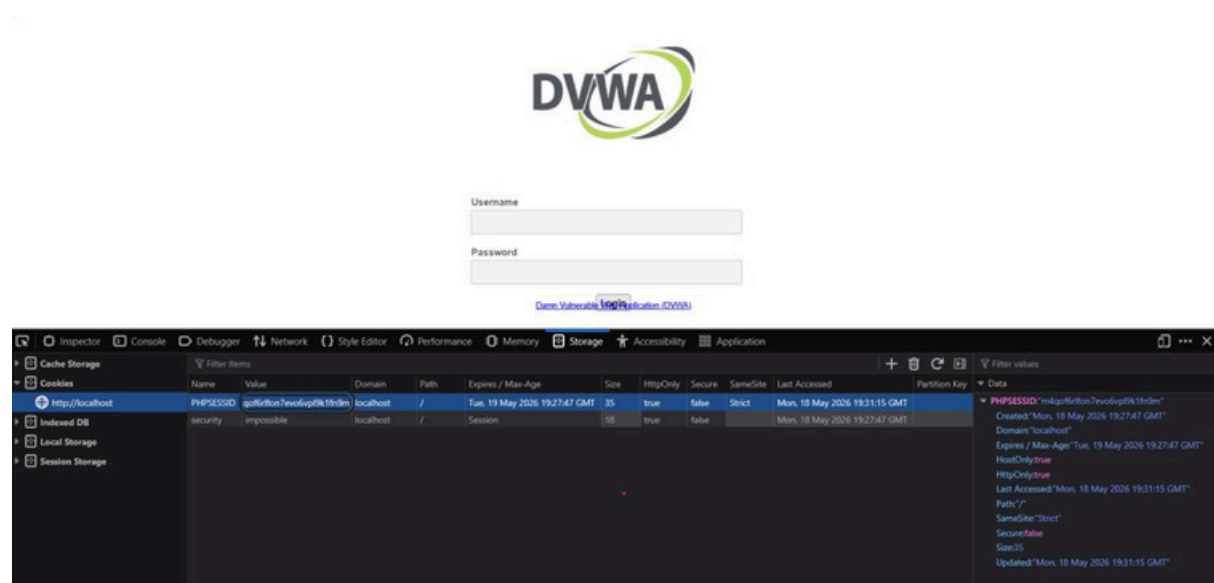
Navigated to:

- Storage
- Cookies
- localhost

Located:

PHPSESSID

Replaced attacker cookie value with victim session ID.

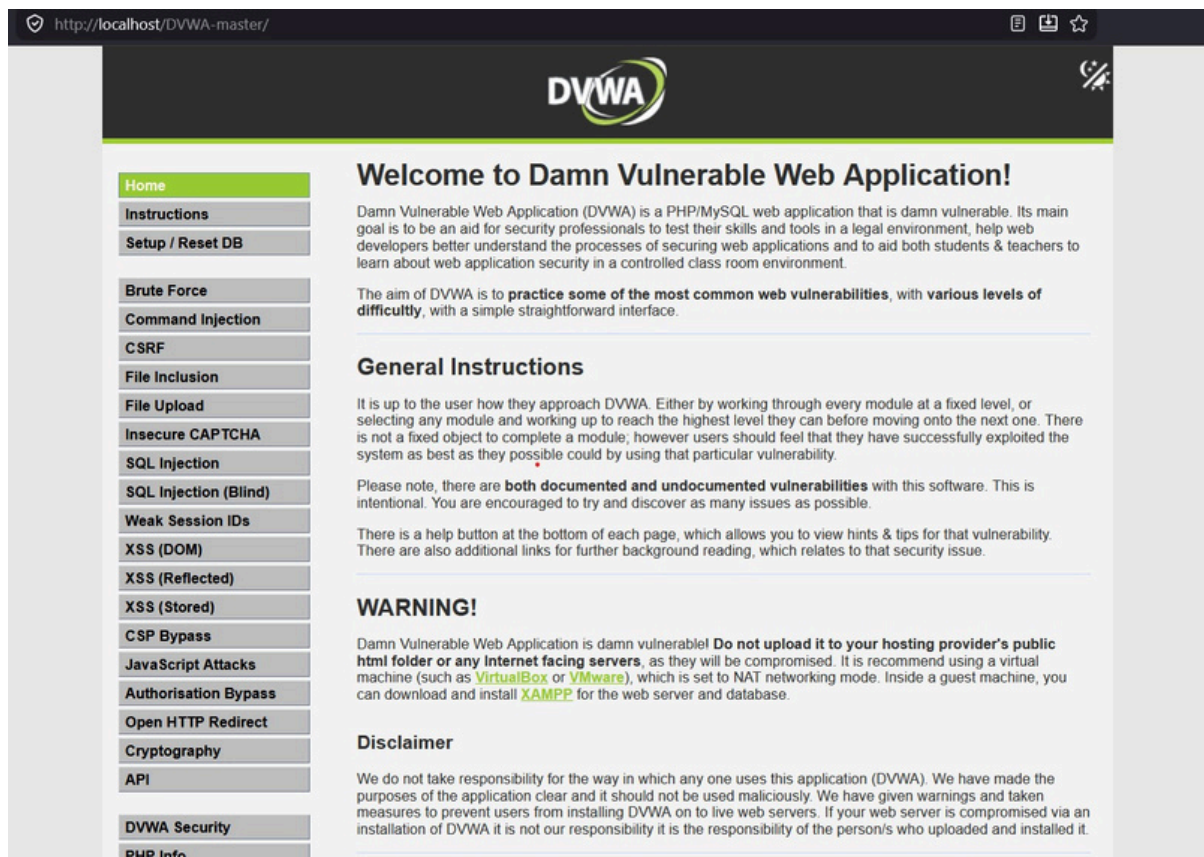


Step 18 — Access Victim Session

Opened:

<http://localhost/DVWA-master/>

The attacker browser successfully accessed the victim's logged-in session without entering credentials.



Observation

- Session IDs stored in browser cookies were used to maintain authenticated sessions.
- Reusing the same session ID allowed another browser to access the authenticated session.

Analysis

- Weak session management may lead to session hijacking vulnerabilities.
- Session cookies must be protected properly to prevent unauthorized access.

Security Risks

- Unauthorized account access
- Session theft
- User impersonation
- Data compromise

Prevention Measures

1. Use HTTPS
2. Enable Secure Cookies
3. Enable HttpOnly Cookies
4. Regenerate Session IDs after login
5. Implement Session Timeout
6. Use Multi-Factor Authentication
7. Validate User-Agent and IP Address